SOC Lab – Week 2

Attack Detection & Incident Response Documentation

---

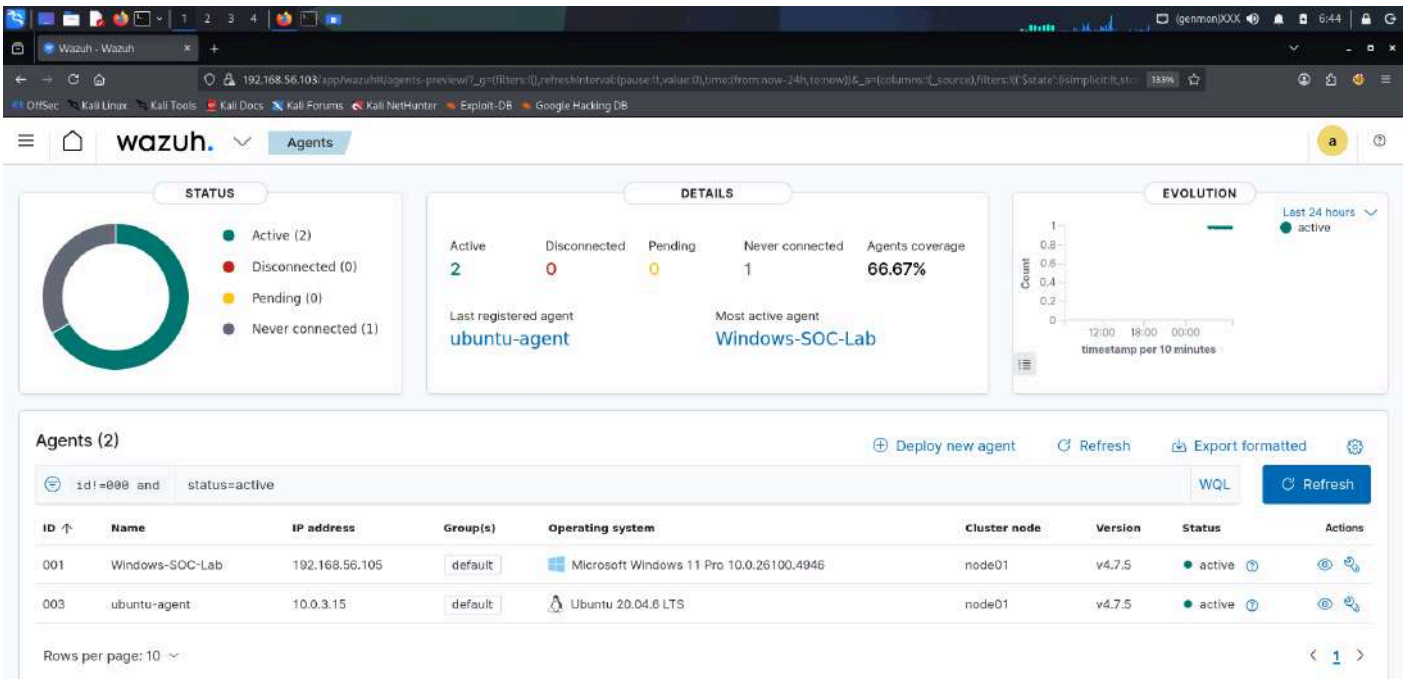
1. Lab Environment Setup

This lab was built using four virtual machines running on Oracle VirtualBox. The Kali Linux machine acted as the attacker, while Ubuntu and Windows 11 were the targets. Wazuh was deployed as the SIEM to monitor and detect all attacks in real time.

Machine	Role	IP Address	OS
Kali Linux	Attacker + Wazuh Server	192.168.56.103	Kali Linux 2026
Ubuntu	Target	10.0.3.15/ 192.168.56.110	Ubuntu 20.04.6 LTS
Windows 11	Target	192.168.56.105	Windows 11 Pro 10.0.26100
Metasploitable	Vulnerable Target	192.168.56.101	Linux (Metasploitable2)
DVWA / Web App	Web Target	192.168.56.104	Linux/Apache

1.1 Wazuh Agents Connected

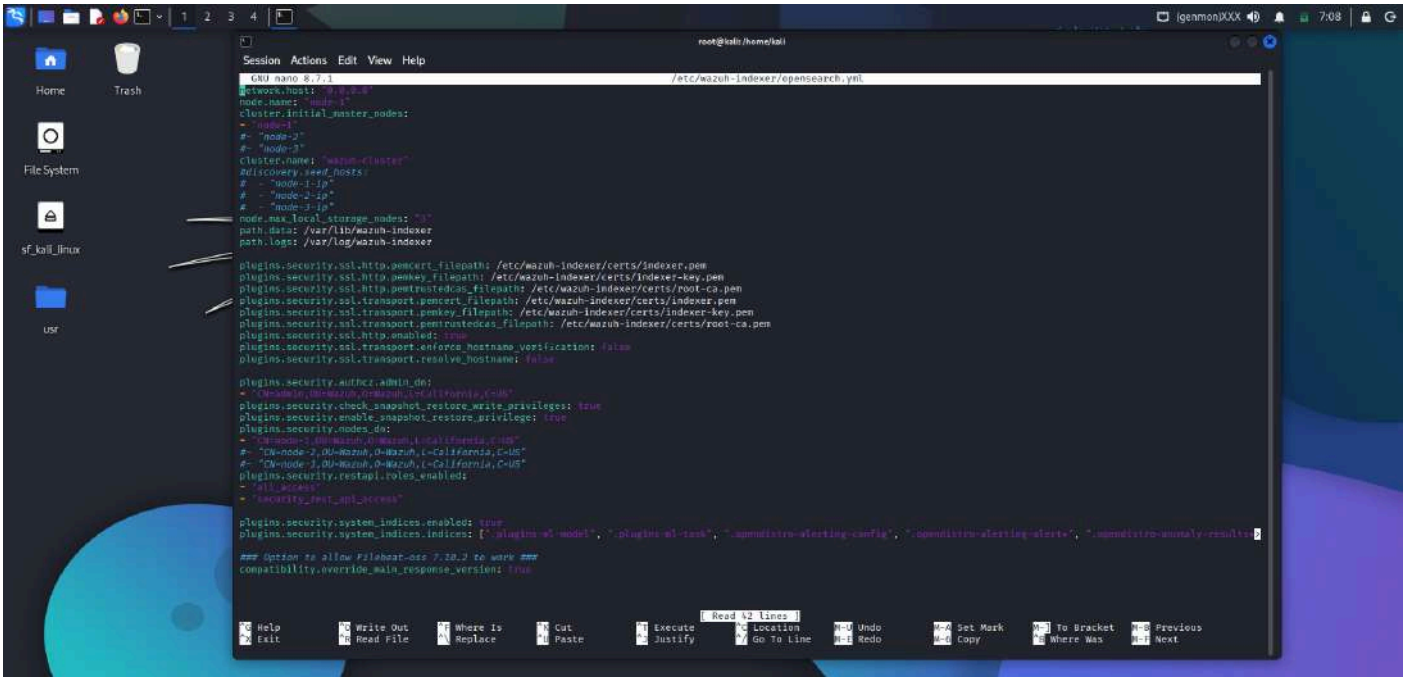
Before any attacks were launched, Wazuh agents were installed and verified as active on both the Ubuntu and Windows machines. This confirms the Preparation phase of the Incident Response lifecycle.



Wazuh Dashboard – 2 Active Agents (Ubuntu + Windows)

1.2 Wazuh Backend Configuration

The Wazuh Indexer (OpenSearch) was configured in /etc/wazuh-indexer/opensearch.yml. Key settings confirmed: listening on all interfaces (0.0.0.0), SSL enabled, single-node cluster named 'wazuh-cluster'.

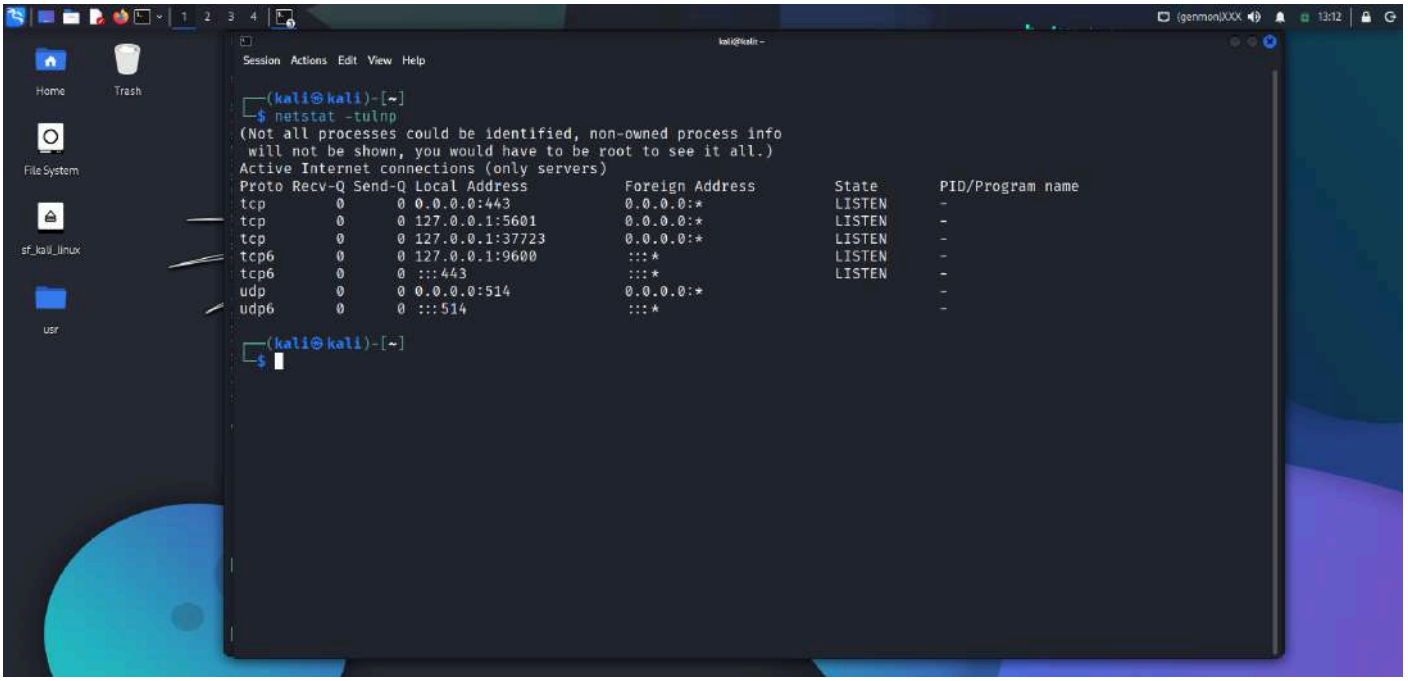


OpenSearch config – /etc/wazuh-indexer/opensearch.yml

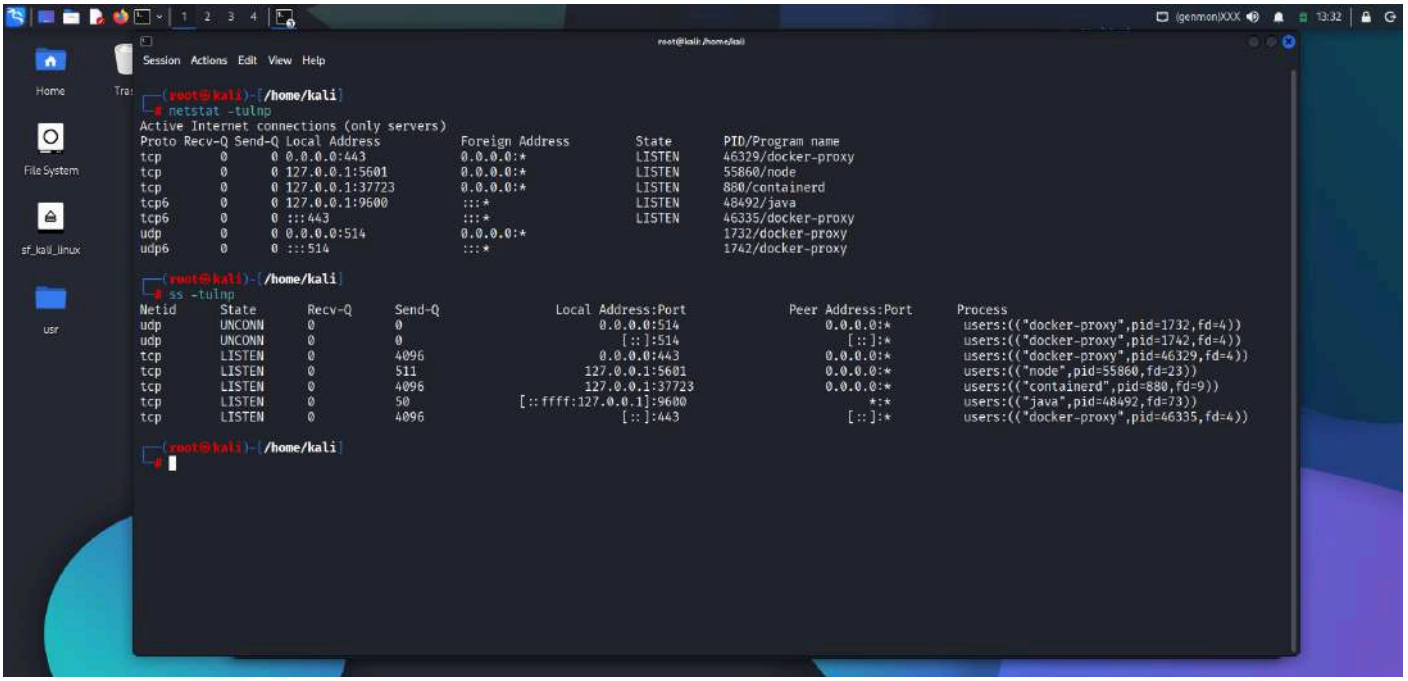
1.3 Wazuh Services Verified (netstat / ss)

Running netstat and ss commands confirmed all Wazuh components were actively listening on the correct ports before attacks began.

Port	Protocol	Process	Purpose
443	TCP	docker-proxy	Wazuh Dashboard (HTTPS)
5601	TCP	node	Wazuh Kibana UI
9600	TCP	java	Wazuh Indexer (OpenSearch)
514	UDP	docker-proxy	Syslog receiver for agent logs



netstat -tulnp (user view) – active listening ports



ss -tulnp (root view) – services with PID details

---

2. Theoretical Knowledge

2.1 Alert Priority Levels

Alert priority tells a SOC analyst which incident needs attention first. It is based on two things: how bad the impact is, and how fast the threat is moving.

Priority	Level	Meaning	Example
Critical	P1	Active attack causing immediate damage	Ransomware encrypting servers right now
High	P2	Serious threat, must act today	Brute force with successful login, Log4Shell exploit
Medium	P3	Risk exists but not immediately critical	SSH brute force attempts (no success yet)
Low	P4	Informational, monitor only	Port scan from a known internal IP

2.2 CVSS Scoring – How Severity is Measured

CVSS (Common Vulnerability Scoring System) gives every vulnerability a score from 0 to 10. The higher the score, the more dangerous the vulnerability. SOC teams use this to decide which alerts to handle first.

CVSS Score	Severity	Priority	Action
9.0 – 10.0	Critical	P1	Respond immediately
7.0 – 8.9	High	P2	Respond same day
4.0 – 6.9	Medium	P3	Respond within 24 hours
0.1 – 3.9	Low	P4	Respond within 72 hours

Real Example: Log4Shell (CVE-2021-44228) scored CVSS 10.0 — it allowed full remote code execution on millions of Java apps. Any alert related to Log4Shell should be treated as P1 Critical and responded to immediately.

2.3 Incident Classification

When an alert comes in, the SOC analyst needs to classify what type of attack it is. This helps choose the right response playbook.

Category	What it means	Example	MITRE ID
Reconnaissance	Attacker is mapping the network to find targets	Nmap port scan, Gobuster directory scan	T1046, T1083
Brute Force	Attacker is guessing passwords repeatedly	Hydra SSH/RDP attack with rockyou.txt	T1110.001
Web Scanning	Attacker is looking for web vulnerabilities	Nikto scan finding phpMyAdmin, missing headers	T1595.003
Credential Access	Attacker is trying to steal or guess login credentials	Authentication failure spikes in Wazuh	T1078
Privilege Escalation	Attacker tries to gain higher-level access	Failed privileged operations on Windows	T1078.002
Malware	Malicious software installed on a system	Ransomware, trojans, spyware	TA0002
Data Exfiltration	Attacker is stealing data from the network	Files sent to external FTP server	T1048

2.4 Incident Response Lifecycle (NIST SP 800-61)

NIST defines 6 phases that every SOC team should follow when responding to an incident. This lab followed all 6 phases.

Phase	What it means	What we did in this lab
1. Preparation	Set up tools and monitoring before anything happens	Installed Wazuh agents on Ubuntu & Windows; verified all services running
2. Identification	Detect that an attack is happening	Wazuh triggered alerts for SSH failures (07:00) and Windows events (07:45)
3. Containment	Stop the attack from spreading	Block attacker IP; isolate affected VM from the network
4. Eradication	Remove the threat completely	Disable default accounts; patch vulnerable services; remove malicious sessions
5. Recovery	Bring systems back to normal	Re-enable services; verify normal login behavior resumes
6. Lessons Learned	Review what happened and improve	Post-mortem written; recommendations documented in this report

---

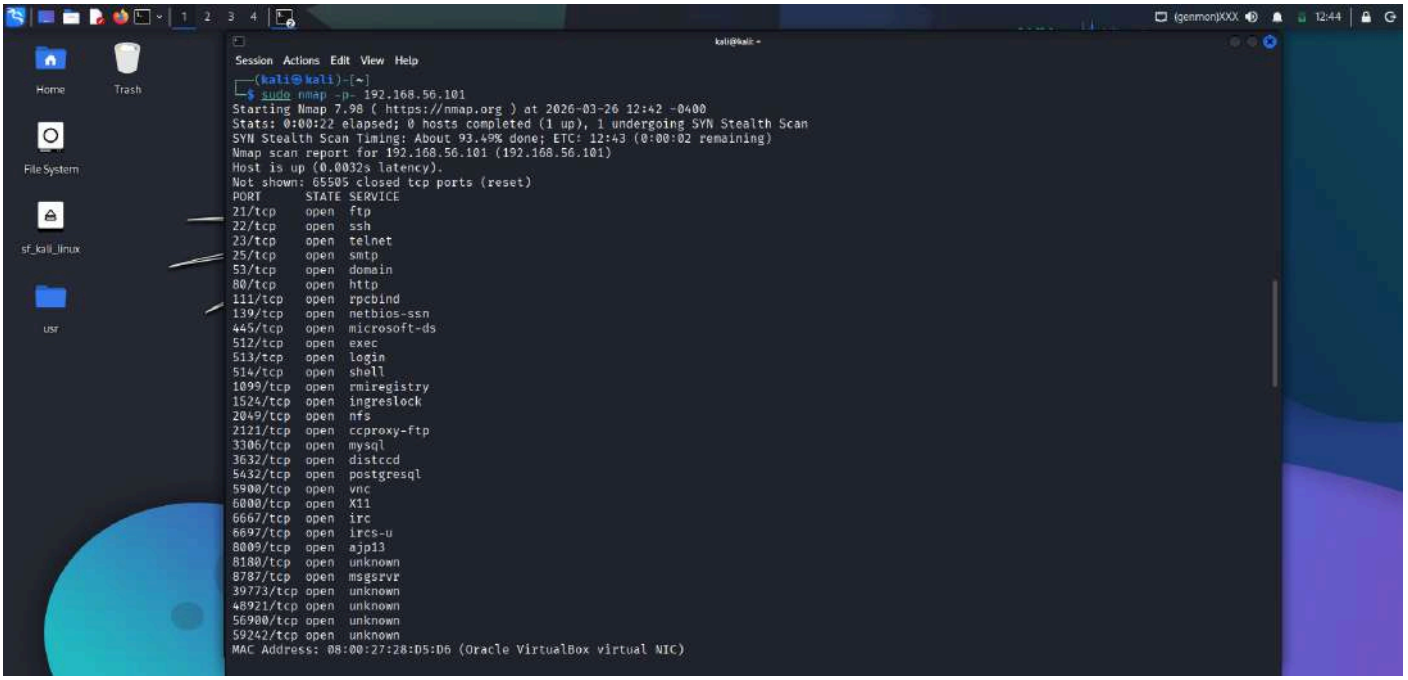
3. Attack Simulation

All attacks were performed from Kali Linux (192.168.56.103) in a controlled lab environment. The goal was to simulate real-world attack techniques and verify that Wazuh could detect them.

3.1 Network Scanning – Nmap

MITRE Technique :-T1046 – Network Service Scanning
Command Used :-sudo nmap -p- 192.168.56.101
Target :-Metasploitable2 – 192.168.56.101
Timestamp :-2026-03-26 06:45

Result: Found 30+ open ports including FTP (21), SSH (22), Telnet (23), HTTP (80), MySQL (3306), VNC (5900), and many more. This confirms the machine is a very vulnerable target.



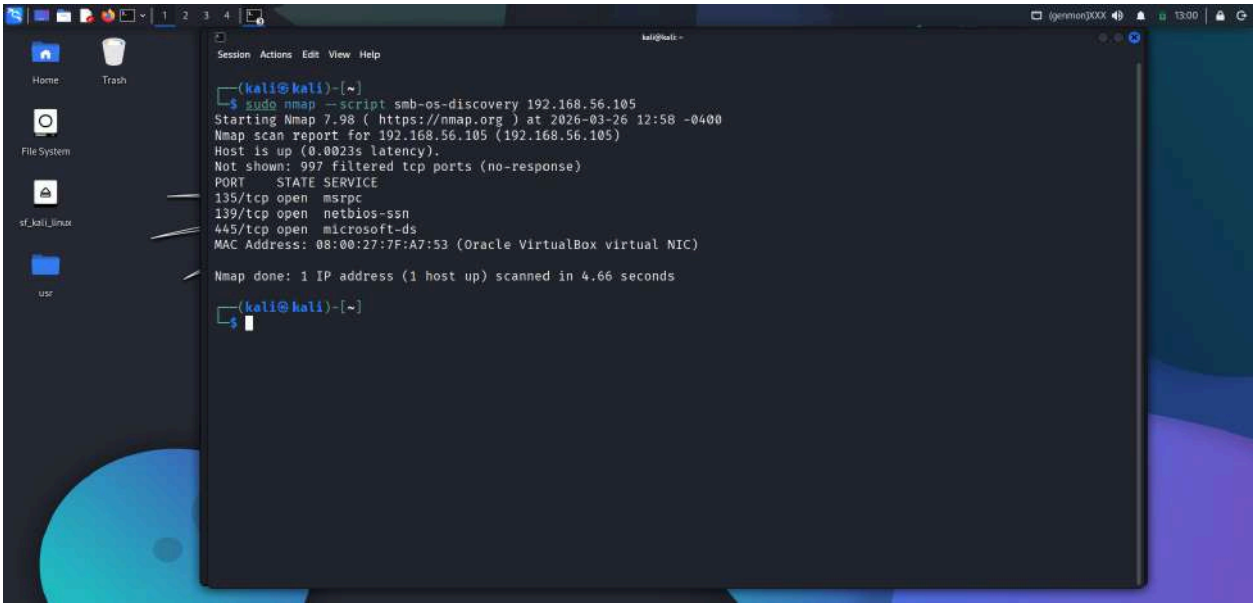
Nmap full port scan – 30+ open ports found on 192.168.56.101

3.2 SMB OS Discovery – Nmap Script

This scan uses an Nmap script to detect what operating system is running on a Windows machine by probing its SMB (file sharing) service.

MITRE Technique :-T1046 + T1135 – Network Service Scanning + Network Share Discovery
Command Used :-sudo nmap --script smb-os-discovery 192.168.56.105
Target :-Windows-SOC-Lab – 192.168.56.105
Timestamp :-2026-03-26 13:00

Result: Found 3 SMB-related ports open — msrpc (135), netbios-ssn (139), microsoft-ds (445).Confirmed target is a Windows machine.



Nmap SMB OS discovery – ports 135, 139, 445 open on Windows target

---

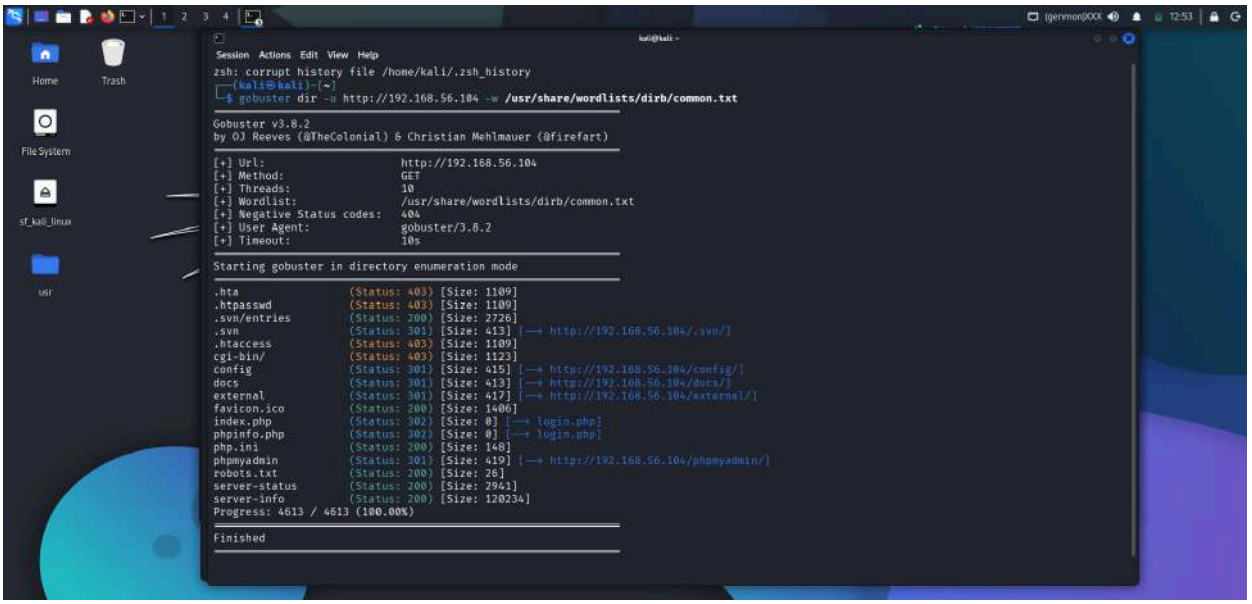
3.3 Web Directory Enumeration – Gobuster

Gobuster is used to find hidden directories and files on a web server by trying thousands of common names from a wordlist. Attackers use this to find admin panels, config files, and sensitive pages.

MITRE Technique :-T1083 – File and Directory Discovery
Command Used :-gobuster dir -u http://192.168.56.104 -w /usr/share/wordlists/dirb/common.txt
Target :-Web Server – 192.168.56.104
Timestamp :-2026-03-26 12:53

Result: Found several critical exposed paths:

- ⚠️ /phpmyadmin – Database admin panel publicly accessible
- ⚠️ /.svn/entries – SVN source code repository exposed (200 OK)
- ⚠️ /server-status – Apache internal server info exposed
- ⚠️ /server-info – Full Apache configuration exposed (120 KB)
- ⚠️ /config – Configuration directory accessible
- ℹ️ /phpinfo.php – PHP configuration details exposed



Gobuster directory scan – critical paths found on 192.168.56.104

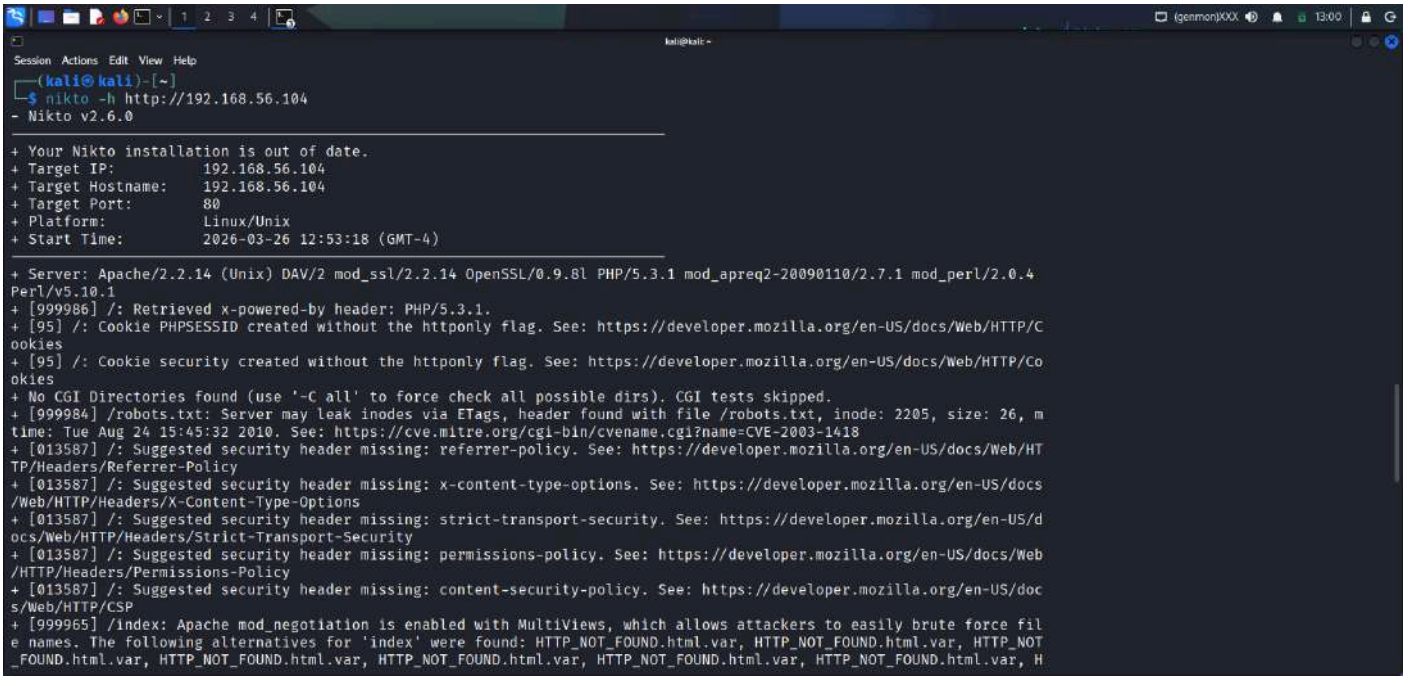
3.4 Web Vulnerability Scan – Nikto

Nikto is a web server scanner that automatically checks for thousands of known vulnerabilities, misconfigurations, and dangerous files on web servers.

MITRE Technique :-T1595.003 – Active Scanning: Wordlist Scanning
Command Used :-nikto -h http://192.168.56.104
Target :-Web Server – 192.168.56.104 (Port 80)
Duration :-2026-03-26 12:53 → 12:59 (360 seconds)
Server Found :-Apache/2.2.14 with PHP/5.3.1 – both outdated and vulnerable

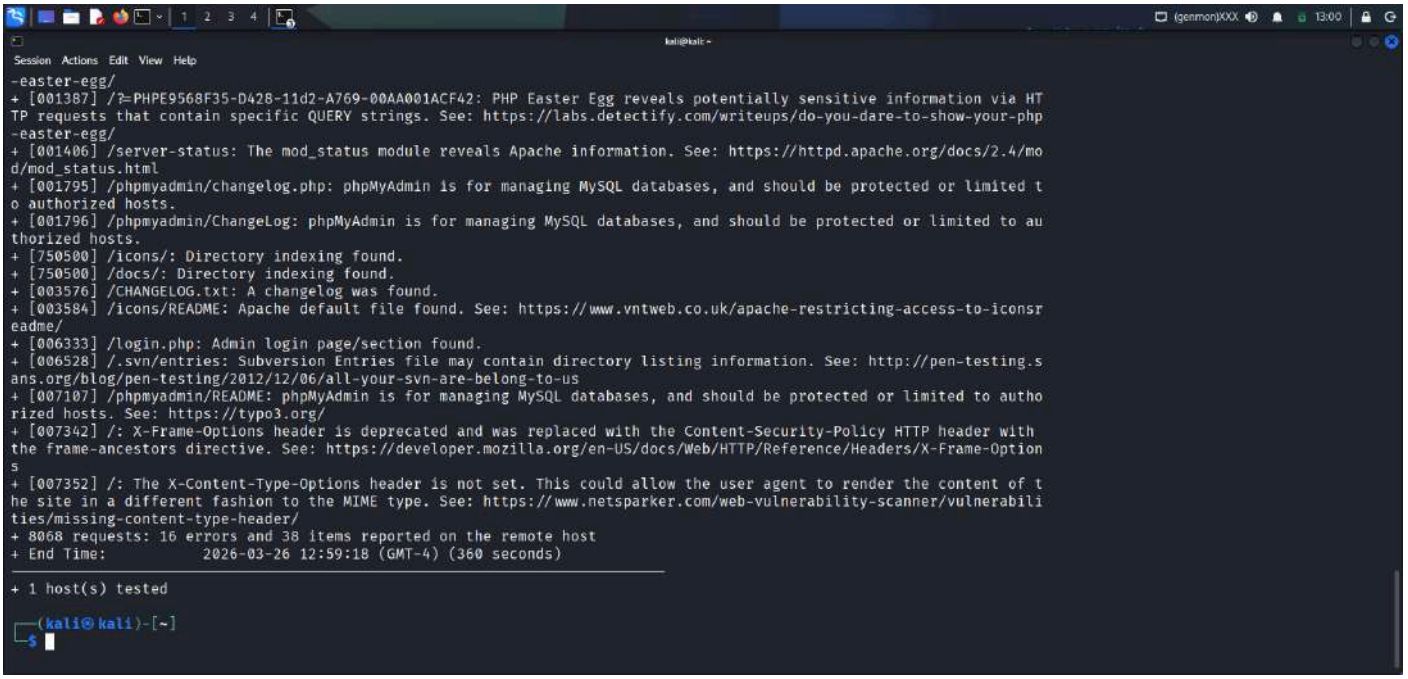
Key issues found by Nikto:

- PHP version 5.3.1 exposed in X-Powered-By header — easy for attackers to target known PHP vulnerabilities
- Cookie PHPSESSID missing 'httponly' flag — session hijacking risk
- 5 security headers missing: referrer-policy, x-content-type-options, strict-transport-security, permissions-policy, content-security-policy
- PHP Easter Egg accessible — leaks sensitive server info
- phpMyAdmin exposed and accessible to anyone — high risk of database compromise
- Admin login page found at /login.php
- SVN entries file accessible — source code directory info leaked
- Directory indexing enabled on /icons/ and /docs/
- Total: 38 issues found across 8068 requests



```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nikto -h http://192.168.56.104
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          192.168.56.104
+ Target Hostname:    192.168.56.104
+ Target Port:        80
+ Platform:           Linux/Unix
+ Start Time:         2026-03-26 12:53:18 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.2.14 (Unix) DAV/2 mod_ssl/2.2.14 OpenSSL/0.9.8l PHP/5.3.1 mod_apreq2-20090110/2.7.1 mod_perl/2.0.4
Perl/v5.10.1
+ [999986] /: Retrieved x-powered-by header: PHP/5.3.1.
+ [95] /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/C
ookies
+ [95] /: Cookie security created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Co
okies
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999984] /robots.txt: Server may leak inodes via ETags, header found with file /robots.txt, inode: 2205, size: 26, m
time: Tue Aug 24 15:45:32 2010. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HT
TP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs
/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/d
ocs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web
/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/doc
s/Web/HTTP/CSP
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force fil
e names. The following alternatives for 'index' were found: HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT
_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, HTTP_NOT_FOUND.html.var, H
```

Nikto scan – server details and vulnerability findings (Part 1)



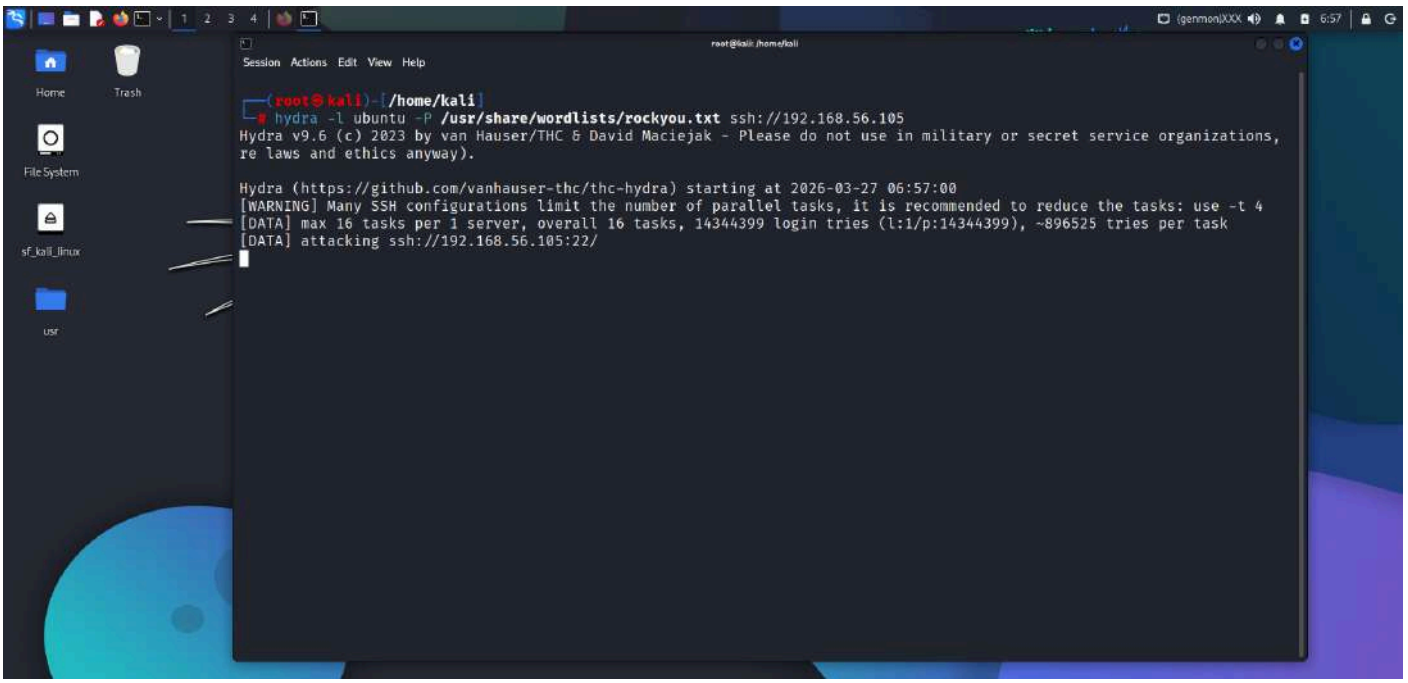
Nikto scan – phpMyAdmin, SVN, directory indexing issues (Part 2)

3.5 SSH Brute Force Attack – Hydra

Hydra is a password-cracking tool that tries thousands of passwords per second against login services. Here it was used to try to guess the SSH password of the Ubuntu machine.

MITRE Technique :-T1110.001 – Brute Force: Password Guessing
Command Used :-hydra -l ubuntu -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.105
Target :-Ubuntu Agent – 10.0.3.15 | Port 22 (SSH)
Timestamp :-2026-03-27 06:57
Wordlist :-rockyou.txt – 14,344,399 passwords

Result: Hydra launched 14.3 million password attempts against SSH port 22. Wazuh detected the flood of authentication failures and raised alerts at 07:00 — just 3 minutes after the attack started.



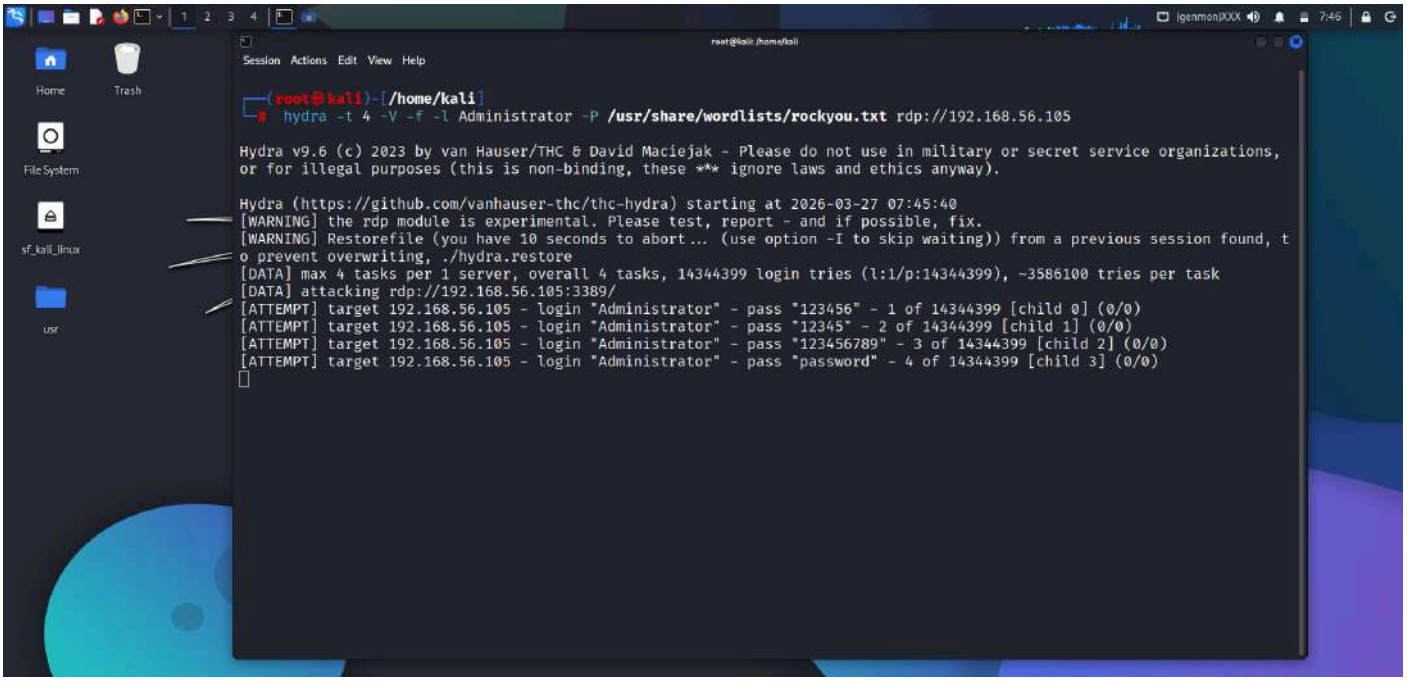
Hydra SSH brute force – attacking ubuntu account on port 22

3.6 RDP Brute Force Attack – Hydra

Same tool (Hydra) but targeting the Windows RDP (Remote Desktop) service on port 3389. This attack tries to guess the Administrator password to gain remote access to the Windows machine.

MITRE Technique :-T1110.001 – Brute Force: Password Guessing
Command Used :-hydra -t 4 -V -f -l Administrator -P /usr/share/wordlists/rockyou.txt rdp://192.168.56.105
Target :-Windows-SOC-Lab – 192.168.56.105 | Port 3389 (RDP)
Timestamp :-2026-03-27 07:45
Account Targeted :-Administrator

Result: Hydra attempted 14.3 million passwords against the RDP service. Wazuh detected failed privileged operations on the Windows agent at 07:45.



Hydra RDP brute force – targeting Administrator account on port 3389

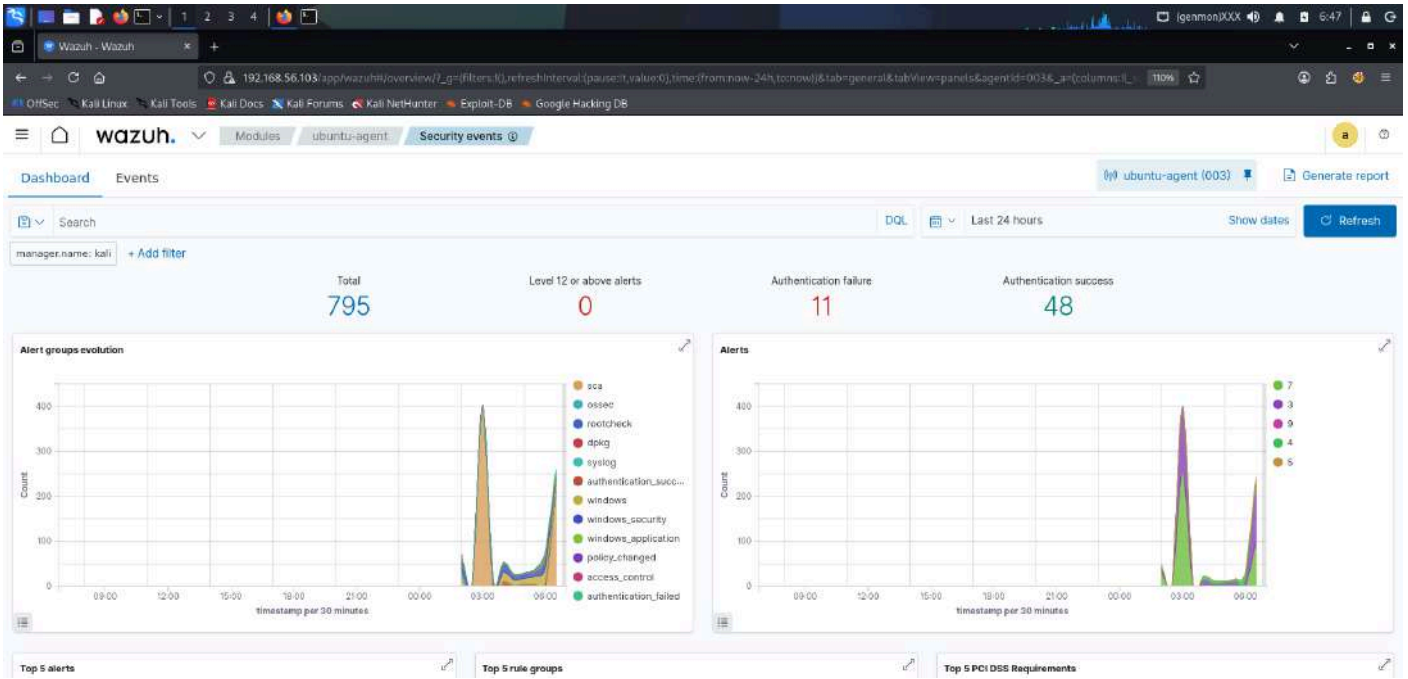
4. Detection in Wazuh

Wazuh successfully detected all brute-force attacks. Below are the dashboard screenshots showing real alerts generated during the attack simulation.

4.1 Ubuntu Agent – Security Events

The ubuntu-agent dashboard showed a spike of 795 total events with 11 authentication failures and 48 authentication successes during the SSH brute force attack period.

Metric	Value	Meaning
Total Events	795	Total security events in last 24 hours
Level 12+ Alerts	0	No critical-level Wazuh alerts triggered
Authentication Failures	11	Failed login attempts detected — attack evidence
Authentication Successes	48	Normal successful logins



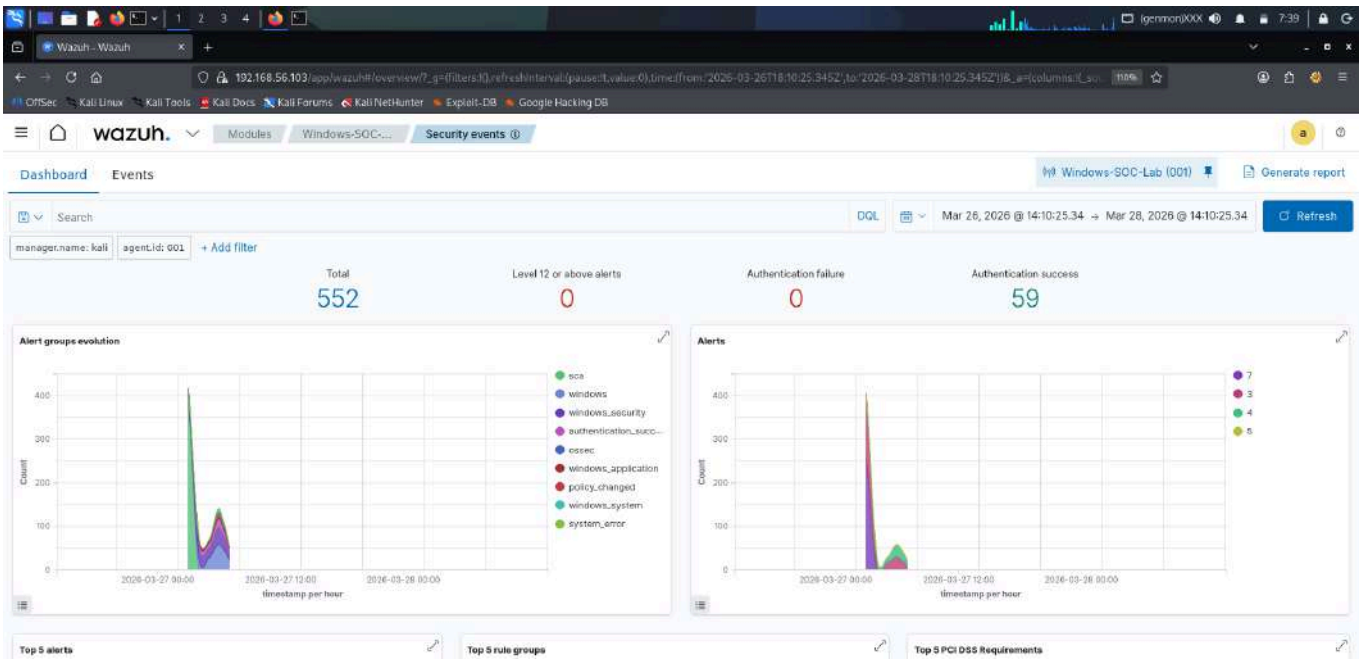
Wazuh – ubuntu-agent security events dashboard showing auth failures

---

4.2 Windows Agent – Security Events

The Windows-SOC-Lab dashboard showed 552 total events during the RDP brute force period. Wazuh detected failed privileged operations on the Windows machine.

Metric	Value	Meaning
Total Events	552	Total security events in the monitoring window
Level 12+ Alerts	0	No critical Wazuh rule triggered
Authentication Failures	0	Windows RDP failures logged differently
Authentication Successes	59	Normal successful logins



Wazuh – Windows-SOC-Lab security events dashboard

5. MITRE ATT&CK Mapping

MITRE ATT&CK is a global framework that maps real-world attack techniques to standardized IDs. Every attack in this lab is mapped below.

#	Attack Performed	Tool	MITRE Tactic	Technique ID	Technique Name
1	Full port scan	Nmap	Reconnaissance	T1046	Network Service Scanning
2	SMB OS discovery	Nmap script	Reconnaissance	T1135	Network Share Discovery
3	Directory enumeration	Gobuster	Reconnaissance	T1083	File & Directory Discovery
4	Web vulnerability scan	Nikto	Active Scanning	T1595.003	Wordlist Scanning
5	SSH brute force	Hydra	Credential Access	T1110.001	Password Guessing
6	RDP brute force	Hydra	Credential Access	T1110.001	Password Guessing
7	Auth failure spike (Ubuntu)	Wazuh detected	Initial Access	T1078	Valid Accounts
8	Failed privileged ops (Win)	Wazuh detected	Privilege Escalation	T1078.002	Domain Accounts
9	Network conn. enumeration	netstat / ss	Discovery	T1049	System Network Connections

6. Alert Classification & Incident Tickets

6.1 Alert Classification Table

Alert ID	Type	Description	Source IP	Priority	MITRE	Status
INC-001	Recon	Nmap full port scan on Metasploitable	192.168.56.103	Medium	T1046	Closed
INC-002	Recon	SMB OS discovery on Windows	192.168.56.103	Medium	T1135	Closed
INC-003	Recon	Gobuster directory scan on web server	192.168.56.103	High	T1083	Closed
INC-004	Web Scan	Nikto web vulnerability scan – 38 issues	192.168.56.103	High	T1595.003	Closed
INC-005	Brute Force	SSH brute force via Hydra + rockyou.txt	192.168.56.103	High	T1110.001	Open
INC-006	Brute Force	RDP brute force via Hydra targeting Admin	192.168.56.103	High	T1110.001	Open
INC-007	Auth Failure	11 auth failures on ubuntu-agent	192.168.56.103	High	T1078	Detected
INC-008	Priv Ops	Failed privileged ops on Windows-SOC-Lab	192.168.56.103	High	T1078.002	Detected

6.2 Incident Ticket – SSH Brute Force

Field	Details
Ticket ID	INC-2026-005
Title	[HIGH] SSH Brute Force on Ubuntu Agent
Date / Time	2026-03-27 06:57
Detected By	Wazuh SIEM (Auto-detection)
Assigned To	SOC Analyst – Tier 1
Priority	HIGH
Affected System	ubuntu-agent – 10.0.3.15
Attacker IP	192.168.56.103 (Kali Linux)
Attack Method	Hydra v9.6 with rockyou.txt targeting port 22 (SSH)
MITRE Technique	T1110.001 – Brute Force: Password Guessing
IOCs	IP: 192.168.56.103 | Tool: Hydra v9.6 | Port: 22 | User: ubuntu | Wordlist: rockyou.txt
Wazuh Alerts	795 total events | 11 auth failures | 48 auth successes
Immediate Actions	1. Block IP 192.168.56.103 at firewall 2. Review /var/log/auth.log 3. Verify no successful unauthorized login occurred
Escalate To	Tier 2 if successful login is confirmed or attack continues

---

6.3 Incident Ticket – RDP Brute Force

Field	Details
Ticket ID	INC-2026-006
Title	[HIGH] RDP Brute Force on Windows-SOC-Lab
Date / Time	2026-03-27 07:39
Detected By	Wazuh SIEM (Auto-detection)
Assigned To	SOC Analyst – Tier 1
Priority	HIGH
Affected System	Windows-SOC-Lab – 192.168.56.105
Attacker IP	192.168.56.103 (Kali Linux)
Attack Method	Hydra v9.6 targeting Administrator account on port 3389 (RDP)
MITRE Technique	T1110.001 – Brute Force: Password Guessing
IOCs	IP: 192.168.56.103 | Tool: Hydra v9.6 | Port: 3389 | User: Administrator
Wazuh Alerts	552 total events | Failed privileged operations detected
Immediate Actions	1. Disable RDP if not required 2. Enable Network Level Authentication 3. Block source IP at firewall
Escalate To	Tier 2 Windows security team if Administrator account is compromised

---

7. Phishing Investigation Checklist

A phishing checklist is used when a suspicious email is reported. The SOC analyst works through each step to confirm whether it is a real attack and what to do next.

Phase 1 – Initial Triage

1	Confirm the phishing email was reported by a user or SIEM alert	[ ]
2	Get a copy of the full email including raw headers	[ ]
3	Check sender address and domain for spoofing	[ ]
4	Verify SPF, DKIM, DMARC records for the sender domain	[ ]
5	Extract all URLs and file attachments from the email	[ ]

Phase 2 – Threat Intelligence Check

#	Check Item	Done?
6	Check link reputation on VirusTotal (virustotal.com)	[ ]
7	Check IP and domain on AlienVault OTX (otx.alienvault.com)	[ ]
8	Search IOCs (IP, hash, domain) in Wazuh/SIEM history	[ ]
9	Check file hash of any attachment on VirusTotal	[ ]

Phase 3 – Containment & Response

#	Check Item	Done?
10	Find all users who received the phishing email	[ ]
11	Find which users clicked the link or opened attachments	[ ]
12	Isolate affected endpoints from the network	[ ]
13	Reset passwords for affected accounts	[ ]
14	Block the malicious URL and sender domain at the gateway	[ ]
15	Purge all copies of the phishing email from the mail server	[ ]
16	Notify management and stakeholders	[ ]
17	Document all findings and actions in an incident ticket	[ ]

---

8. Threat Intelligence – AlienVault OTX

AlienVault OTX (Open Threat Exchange) is a free threat intelligence platform. SOC analysts use it to check whether an IP address, domain, or file hash is known to be malicious.

8.1 IOC Validation

IOC	Value	OTX Result	Verdict
IP Address	192.168.56.103	Private RFC1918 IP – not in OTX (lab environment)	Internal lab IP – safe
Attack Pattern	SSH Brute Force	Matches OTX Pulse: 'SSH Brute Force Campaigns'	Confirmed real threat pattern
Attack Pattern	RDP Brute Force	Matches OTX Pulse: 'RDP Attacks on Windows'	Confirmed real threat pattern
Tool	Hydra v9.6	Known in OTX as password brute-force tool	Known attack tool
Wordlist	rockyou.txt	Associated with credential attacks in OTX pulses	Confirmed IOC context

---

8.2 Summary

The attacker IP is a private lab address so it is not in OTX. However, the attack techniques — SSH and RDP brute force using Hydra with rockyou.txt — are well-documented real-world threat patterns confirmed in OTX. If this same attack came from an external IP, it would immediately match known threat actor campaigns and should be treated as a confirmed HIGH-priority incident.

---

9. Evidence Preservation & Chain of Custody

All evidence was collected immediately during or after each attack. No files were modified after capture. All screenshots are stored in the /images folder of the GitHub repository.

Item	Evidence Type	Description	Timestamp	File
E-001	Screenshot	Wazuh agents – Ubuntu & Windows connected	2026-03-26 06:44	Wazuh-Agents.png
E-002	Screenshot	Wazuh OpenSearch backend config	2026-03-26 07:08	Screenshot_2026-03-26_07_08_08.png
E-003	Screenshot	Nmap full port scan on Metasploitable	2026-03-26 06:45	nmap_scan.png
E-004	Screenshot	Nmap SMB OS discovery on Windows	2026-03-26 13:00	Screenshot_2026-03-26_13_00_01.png
E-005	Screenshot	Gobuster directory scan on web server	2026-03-26 12:53	Screenshot_2026-03-26_12_53_36.png
E-006	Screenshot	Nikto web vulnerability scan – part 1	2026-03-26 12:53	Screenshot_2026-03-26_13_00_30.png
E-007	Screenshot	Nikto web vulnerability scan – part 2	2026-03-26 12:59	Screenshot_2026-03-26_13_00_40.png
E-008	Screenshot	netstat -tulnp (user view)	2026-03-26 13:12	Screenshot_2026-03-26_13_12_32.png
E-009	Screenshot	netstat + ss -tulnp (root view)	2026-03-26 13:32	Screenshot_2026-03-26_13_32_15.png
E-010	Screenshot	SSH brute force – Hydra terminal output	2026-03-27 06:57	ssh-bruteforce.png
E-011	Screenshot	RDP brute force – Hydra terminal output	2026-03-27 07:45	rdp-bruteforce.png
E-012	Screenshot	Wazuh ubuntu-agent alerts dashboard	2026-03-27 07:00	ubuntu-alerts.png
E-013	Screenshot	Wazuh Windows-SOC-Lab alerts dashboard	2026-03-27 07:39	windows-alert.png
E-014	PDF	Full SOC Lab Attack Detection Report	2026-03-27	Week 2 -SOC Lab – Attack Detection Report.pdf

---

10. Post-Mortem & Lessons Learned

10.1 What Went Well

- Wazuh successfully detected both SSH and RDP brute-force attacks automatically
- Alerts were triggered within 3–6 minutes of attacks starting — fast detection
- Both Ubuntu and Windows agents reported events correctly
- Full attack timeline was captured clearly with screenshots

10.2 What Could Be Improved

- No account lockout policy was active — attacker could try unlimited passwords
- No automated IP blocking — attacker's IP was never auto-blocked during the attack
- No real-time notifications — no email or Slack alert was sent during the attack
- Web server (192.168.56.104) had critical misconfigurations — phpMyAdmin and SVN publicly exposed

---

10.3 Security Recommendations

#	Recommendation	Priority	How to Implement
1	Account lockout after 5 failed attempts	High	Windows GPO / Linux faillock or pam_tally2
2	Deploy fail2ban on Ubuntu	High	sudo apt install fail2ban + configure jail.conf
3	Enable Wazuh Active Response (auto-block attacker IPs)	High	Configure active-response block in ossec.conf
4	SSH key-based auth only – disable password login	High	Set PasswordAuthentication no in sshd_config
5	Disable RDP if not needed; enable NLA	High	Windows Security Policy → Remote Desktop
6	Restrict phpMyAdmin to localhost only	Critical	Apache config: Allow from 127.0.0.1 only
7	Disable SVN directory public access	High	Apache config: Deny from all in .svn location block
8	Add missing security headers to Apache	Medium	Add Header directives in Apache .conf
9	Upgrade PHP from 5.3.1 to supported version	Critical	sudo apt upgrade php
10	Wazuh email/Slack alerts for High events	Medium	Configure email/webhook in ossec.conf